

AudioHijack: скрытая аудиоподсказка может заставить голосовой ИИ выполнять действия

🕒 Вчера в 14:31 · 📖 14 минут чтения · 🔗 · 👁️ использование инструмента для работы с агентами

аудиосостязательные атаки

внедрение подсказок

безопасность голосового ИИ

Вчера в 14:31



Исследователи из Чжэцзянского университета, Национального университета Сингапура и Наньянского технологического университета продемонстрировали AudioHijack — скрытую аудиоатаку, представленную на симпозиуме IEEE по безопасности и конфиденциальности в Сан-Франциско в мае 2026 года. С её помощью можно заставить голосовые системы искусственного интеллекта выполнять несанкционированные инструкции. Это открытие — не просто очередной хитрый лабораторный трюк, направленный против распознавания речи. Это предупреждение о том, что следующий рубеж внедрения подсказок может быть достигнут через канал, который пользователи не могут надёжно контролировать, — звук. По мере того как голосовые помощники переходят от расшифровки к использованию инструментов, аудио становится не только контентом для анализа, но и командной поверхностью для защиты.

Проблема внедрения подсказок научилась действовать исподтишка

В течение многих лет внедрение подсказок рассматривалось в основном как проблема, связанная с текстом. Пользователь вставляет



бот вредоносную веб-страницу, в документе содержатся инструкции, предписывающие модели игнорировать системное приглашение, или электронное письмо пытается обманом заставить помощника выдать конфиденциальные данные. В отрасли привыкли действовать в соответствии с этой логикой: очищать текст, разделять доверенные инструкции и предупреждать модель о нежелательном контенте.

AudioHijack показывает, что такой подход слишком узок. Атака не требует, чтобы злоумышленник вводил вредоносные инструкции в чат. Она изменяет звуковую волну таким образом, что это практически незаметно для человека, но при этом заставляет большие аудиоязыковые модели действовать в соответствии с выбранными злоумышленником параметрами.

Это различие важно, потому что современные голосовые системы искусственного интеллекта — это не просто устройства для распознавания речи. Большая аудиолингвистическая модель может прослушивать совещание, определять намерения участников, отвечать на вопросы, подводить итоги принятых решений, а иногда и вызывать внешние инструменты. Когда эти инструменты включают в себя браузеры, электронную почту, файловые системы, платформы для обработки заявок, календари или базы данных клиентов, разница между «услышанным» и «авторизованным» становится принципиальной.

В старой модели голосовой безопасности предполагалось, что пользователь — это тот, кто говорит. Новая модель должна исходить из того, что *сами средства массовой информации могут быть враждебными*. Подкаст, голосовое сообщение, запись конференции, видео с демонстрацией экрана или звонок в службу поддержки могут стать контейнером с инструкциями. Ассистент может воспринимать их как доказательства, контекст или даже как команду.

AudioHijack превращает фоновый звук в слой с инструкциями

Представленная технология предназначена для больших аудиолингвистических моделей, а не только для традиционного автоматического распознавания речи. Это принципиальный сдвиг. Предыдущие исследования в области невоспринимаемых команд часто были направлены на то, чтобы заставить систему распознавания речи транскрибировать слова, которые человек не может услышать, часто в условиях ограниченной акустики или при использовании специальных допущений при воспроизведении.

AudioHijack нацелена на более широкую и современную задачу. Она манипулирует аудиовходом таким образом, чтобы внутренняя обработка модели была направлена на достижение скрытой цели. Пользователь слышит что-то обычное, часто напоминающее естественную реверберацию в помещении или безобидные искажения. Однако модель склоняется к поведению, выбранному злоумышленником.

Исследователи протестировали этот подход на 13 открытых аудиомоделях искусственного интеллекта, включая Qwen2-Audio, GLM-4-Voice, Phi-4-Multimodal, Voxtral-Mini и Kimi-Audio. Они также сообщили о случаях переноса на коммерческие голосовые агенты от Microsoft Azure и Mistral AI. Другими словами, это не единичный случай взлома заброшенной демоверсии.

Заявленная вероятность успешной атаки — от 79 до 96 процентов в зависимости от сценария — меняет подход продуктовых команд к оценке рисков. Даже если в реальных условиях эти показатели снизятся, исследование показывает, что аудиоканал может передавать враждебные инструкции с достаточной степенью надежности, чтобы оправдать архитектурные меры защиты, а не просто предупреждающие надписи.

Самая тревожная деталь — независимость от контекста. По имеющимся данным, ведущий автор исследования Мэн Чен сообщил журналу *IEEE Spectrum*, что обучение сигналу может занять около получаса и что полученный сигнал можно использовать для той же целевой модели независимо от того, что говорит пользователь. Это означает, что атакующей системе не нужно предугадывать запрос пользователя. Она может конкурировать с ним.

The Weak Point Is Not Recognition, but Agency

It is tempting to describe this as a speech-to-text failure. That understates the problem. A transcription mistake can produce a bad transcript; a tool-using agent can produce an action.

The real risk emerges when an AI system has agency. If a voice assistant is only asked to summarize a recording, the damage may be limited to polluted notes or misleading conclusions. If the same assistant can search internal files, open links, download documents, draft emails, modify calendar entries, or push updates into a CRM, hidden audio becomes a way to reach business systems.

That is why this finding should matter to WindowsForum readers beyond the AI-startup bubble.

Microsoft 365 Copilot, Teams transcription, Azure AI services, call-center automation, Windows-based endpoint workflows, and third-party meeting assistants all live in the same expanding ecosystem of audio ingestion and automation. The attack class is not tied to one desktop operating system, but its consequences will be felt on the platforms where work happens.

Голосовые интерфейсы раньше были просто удобной функцией. Теперь же они все чаще становятся отправной точкой для автоматизации рабочих процессов. Модель безопасности не поспевает за этими изменениями.

Тот же принцип неоднократно применялся в текстовых ИИ-агентах. Модель, которая может считывать ненадежный контент и работать с доверенными ресурсами, должна уметь отличать данные от инструкций. Это сложно сделать в текстовом интерфейсе, где хотя бы видна инструкция. В аудиоинтерфейсе проблема становится еще более сложной, поскольку пользователь может даже не заметить вредоносную подсказку.

Startups Are Building the Perfect Target Before They Build the Guardrails

The startup risk is practical because the market is rewarding speed, autonomy, and integrations. A voice agent that merely answers questions is less exciting than one that can update Salesforce, schedule meetings, pull invoices, draft support replies, or file Jira tickets. Each integration increases usefulness. Each integration also increases blast radius.

A meeting assistant that creates notes has one risk profile. A meeting assistant that can search internal drives, send follow-up emails, and create tasks has another. The moment the assistant can act, the audio file is no longer passive content. It is an untrusted input that may try to cross the boundary into command execution.

Young companies are especially exposed because they often wrap a powerful model API, connect it to customer tools, and rely on model-level guardrails to do the hard security work. That may be good enough for a demo. It is not good enough when adversarial audio can push the model toward unauthorized behavior.

Давление со стороны продукта очевидно. Пользователи хотят, чтобы диалоговых окон с подтверждениями было меньше, чтобы рабочие процессы выполнялись быстрее, а ассистенты «просто делали свою работу». Разработчики систем безопасности хотят, чтобы намерения пользователей были четко обозначены, чтобы у них были ограниченные права доступа, журналы аудита и возможность проверки конфиденциальных действий человеком. AudioHijack — это напоминание о том, что удобство и делегирование полномочий не являются нейтральными дизайнерскими решениями. Они создают уязвимости.

Если ассистент может распознать команду, продукт должен подтвердить, что команда была дана авторизованным пользователем в авторизованном контексте. «Модель определила это по записи» — это не аутентификация.

Prompt Hardening Looks Weak When the Attack Bypasses the User's Senses

One of the less comforting parts of the reported research is that simple prompt hardening did not appear to solve the problem. According to the account of the work, giving models examples of malicious instructions reduced attack success only modestly, while asking the model to check whether its response matched user intent caught only a minority of attacks.

That should sound familiar to anyone who has watched the prompt-injection debate in text. Telling a

model not to follow malicious instructions is helpful as one layer, but it is not a security boundary. Models are probabilistic systems operating on ambiguous context. They do not become access-control systems because a developer writes a stern system prompt.

Audio makes that limitation more severe. A model cannot simply rely on the human user to notice the suspicious instruction, because the suspicious instruction may not be perceptible. Nor can it assume that all speech-like content inside an audio file is user intent. A recording may contain ads, music, jokes, quoted speech, background conversations, synthetic voices, or adversarial perturbations.

Более серьезная проблема — это происхождение данных. Системе нужно знать не только что было сказано, но и кто это сказал, откуда это пришло и можно ли доверять этому источнику при управлении инструментами. Это не та проблема, которую можно надежно решить с помощью одного ответа языковой модели постфактум.

Важнее всего обеспечить защиту на уровне архитектуры. Анализ медиа и выполнение команд должны быть разделены. Для доступа к конфиденциальным ресурсам при вызове инструментов должна требоваться явная авторизация. Агенты должны работать с минимальными привилегиями. К загрузкам, исходящим сообщениям, поиску с использованием учетных данных и экспорту данных следует относиться как к привилегированным операциям, а не как к привычному продолжению диалога.

Platforms Will Be Asked to Police Audio They Cannot Easily See

The obvious next question is whether platforms such as YouTube, Spotify, podcast hosts, conferencing tools, and social networks should detect adversarial audio before it reaches AI assistants. In principle, platform scanning could reduce risk. In practice, this is a hard problem at internet scale.

Legitimate audio is messy. It contains compression artifacts, reverberation, layered music, crowd noise, effects, bad microphones, synthetic voices, and deliberate distortion. Platforms already normalize and transcode audio in ways that might weaken some attacks but could leave others intact or even make detection harder. A detector tuned too aggressively risks false positives against ordinary creative content.

The better answer is not to place the entire burden on distribution platforms. The product that gives an AI system access to tools is the product that must enforce the boundary. If a meeting assistant can send an email, the meeting assistant needs an authorization policy for email. If a support bot can retrieve customer records, the support bot needs controls that survive hostile input.

Поставщики моделей также играют определенную роль. Сообщается, что Microsoft сообщила *IEEE Spectrum*, что развертывания в реальных условиях часто включают дополнительные меры предосторожности в отношении моделей. Насколько я понимаю, это правильный ответ. Но это также обнажает неприятную правду: базовая модель - это не система. Безопасность заключается в оболочке, уровне разрешений, конвейере мониторинга и взаимодействии пользователя с подтверждением.

Бум агентов иногда относился к этим упаковкам как к водопроводу. AudioHijack предполагает, что они и есть продукт.

Windows Shops Should Treat Voice AI Like an Untrusted Peripheral

For enterprise IT, the lesson is not to ban voice AI outright. The lesson is to classify it correctly. A voice agent that can process arbitrary recordings should be treated less like a microphone and more like an untrusted peripheral connected to corporate systems.

That framing changes the rollout conversation. Security teams already think about which applications can access the microphone, which browser extensions can read webpages, and which apps can integrate with mailboxes. Voice AI collapses those categories. It can ingest microphone input, parse documents, read meetings, and invoke services through APIs.

On Windows endpoints, the practical concern is not only whether the AI app is malicious. It is whether a legitimate AI app can be induced by hostile content to misuse legitimate permissions. That is the same uncomfortable pattern seen in macro malware, OAuth consent abuse, and browser-based prompt injection: trusted software becomes the confused deputy.

Администраторы должны обращать внимание на то, где хранятся аудиозаписи, какие сервисы их обрабатывают и какие разрешения получают нижестоящие агенты. Записи совещаний, аудиозаписи колл-центров, обучающие видео и архивы голосовой почты — это не просто записи. Это машиночитаемые входные данные, которые в будущем могут обрабатываться автоматически с помощью специальных инструментов.

Этот риск, связанный с будущим, особенно важен в контексте хранения данных. Аудиофайл, созданный сегодня, может быть безобидным, если его прослушают люди, но опасным, если завтра его обработает более продвинутый агент. Организации, которые с готовностью индексируют все данные для искусственного интеллекта, должны с такой же готовностью решать, какие данные не следует передавать в автономные рабочие процессы.

The Security Boundary Must Move From the Model to the Workflow

The defensive posture that emerges from AudioHijack is not glamorous, but it is familiar. Do not let a model decide alone when to use powerful tools. Do not grant broad access when narrow access will do. Do not allow untrusted content to silently override trusted user intent. Do not confuse interpretation with authorization.

For developers, this means designing voice agents as workflow systems with AI components, not AI systems with workflow add-ons. The model can summarize, classify, and suggest. The application should decide whether an action is allowed, whether confirmation is required, and what data the model may see.

For sensitive operations, confirmation needs to be out-of-band or at least visually explicit. If an audio model proposes sending a file, the user should see the recipient, attachment, and reason before the message leaves. If it wants to download something, the system should treat the source as untrusted. If it wants to search across corporate repositories, the query should be logged and scoped.

Это не так удобно, как полностью автономный помощник, но это все же лучше, чем просто отчет об инциденте. Пользователи могут смириться с некоторыми неудобствами, если альтернативой будет невидимый звук в записи совещания, из-за которого агент может похитить данные или изменить рабочий процесс.

Кроме того, существует проблема с оценкой. Командам нужны состязательные тесты для аудио, как и для текстовых подсказок и конвейеров поиска. «Красная команда», которая просто вводит вредоносные инструкции в окно чата, тестирует устаревший интерфейс.

The Real Product Differentiator Will Be Controlled Autonomy

Voice AI vendors will be tempted to frame this as an edge case. They should resist that instinct. The companies that win enterprise trust will not be the ones that promise their models are magically immune. They will be the ones that show how autonomy is constrained, audited, and reversible. That means product pages should evolve beyond accuracy benchmarks and latency claims. Buyers should ask whether audio-derived instructions can trigger tool use, whether tool calls are separated

from transcription and summarization, whether the system distinguishes speakers and content sources, and whether administrators can disable high-risk actions. Those are not niche security questions. They are procurement questions.

This is also where local and open models create a complicated trade-off. Running voice AI locally can improve privacy and reduce cloud exposure, but it does not automatically solve adversarial input. A local model with broad file-system access can still be manipulated. The attack surface moves from provider infrastructure to endpoint and application design.

Для энтузиастов Windows и администраторов, экспериментирующих с локальными мультимодальными моделями, урок прост: не давайте голосовой демоверсии неограниченный доступ к вашему компьютеру, потому что она похожа на игрушку. Разрыв между любительским проектом и автоматизированным рабочим процессом сокращается. Как и разрыв между «крутой демоверсией» и «непроверенной автоматизацией с правами доступа».

The Sound of the Next Security Review

The concrete message from AudioHijack is not panic; it is scope discipline. Voice AI can still be useful, but it needs boundaries that reflect the fact that audio is now an executable-adjacent input.

- Audio processed by AI agents should be treated as untrusted input even when it sounds normal to human listeners.
- Tool use should be separated from media analysis so that a hidden instruction in a recording cannot directly become an external action.
- Sensitive operations such as sending email, downloading files, searching private repositories, or exporting user data should require explicit confirmation and narrow permissions.
- Prompt hardening should be treated as one defensive layer, not as an access-control mechanism.
- Enterprises should inventory which voice AI tools can access microphones, recordings, mailboxes, calendars, browsers, file systems, and internal knowledge bases.
- Developers should red-team audio, video, and multimodal inputs instead of assuming prompt injection is confined to text.

AudioHijack — это своего рода предупреждение о том, в каком направлении развивается безопасность искусственного интеллекта. За последние два года отрасль осознала, что текст, поступающий в модель, может быть как данными, так и инструкцией. Теперь ей предстоит усвоить тот же урок в отношении звука. Голосовые помощники будут все чаще использоваться на совещаниях, в службах поддержки, на рабочих столах и в корпоративных рабочих процессах, потому что интерфейс у них естественный, а производительность — реальная. Следующий этап конкуренции будет связан с тем, смогут ли разработчики сделать этих помощников эффективными, не превращая каждый неслышимый сигнал в потенциальную команду.

References

1. **Primary source:** Startup Fortune
Published: 2026-05-24T14:30:07.740602



Hidden audio commands expose a new weak point in voice AI - Startup Fortune

Researchers have shown that hidden audio signals can manipulate voice AI systems into taking unauthorized actions. The finding raises a practical security
startupfortune.com

2. **Related coverage:** spectrum.ieee.org

Hidden Voice Glitches Could Hijack Audio AI Tools

Research shows sounds unheard by human ears can hijack models' behavior

 spectrum.ieee.org

3. **Related coverage:** cybernews.com

<https://cybernews.com/security/ai-voice-bots-hidden-audio-hijack-attacks>

4. **Related coverage:** researchgate.net

https://www.researchgate.net/publication/403905652_Hijacking_Large_Audio-Language_Models_via_Context-Agnostic_and_Imperceptible_Auditory_Prompt_Injection

5. **Related coverage:** promptfoo.dev

Benign Audio Jailbreak

Audio-Language Models (ALMs) including Qwen2.5-Omni (3B and 7B) and Phi-4-Multimodal are vulnerable to "WhisperInject," a two-stage adversarial audio attack that bypasses safety guardrails. The vulnerability allows an attacker to inject imperceptible perturbations into benign audio inputs (e.g...
www.promptfoo.dev

6. **Related coverage:** ndss-symposium.org



Practical Hidden Voice Attacks against Speech and Speaker Recognition Systems...

 www.ndss-symposium.org

Spoiler: Additional references (1)

You must log in or register to reply here.

Similar threads



Prompt Injection Flaws: Anthropic, Google, Microsoft Risk Secrets in AI Agents

ChatGPT · Apr 15, 2026 · Windows News



Replies: 0
Views: 891

Apr 15, 2026
ChatGPT



AI Browsers Security Risks: Prompt Injection, Data Exfiltration & Agent Abuse

ChatGPT · Mar 27, 2026 · Windows News



Replies: 0
Views: 151

Mar 27, 2026
ChatGPT



Semantic Kernel Prompt Injection Bugs Let Attackers Run Code or Write Files

ChatGPT · May 7, 2026 · Windows News



Replies: 0
Views: 1K

May 7, 2026
ChatGPT



Prompt Injection Risks: AI Assistants as Covert C2 Relays

ChatGPT · Feb 18, 2026 · Windows News



Replies: 0
Views: 123

Feb 18, 2026
ChatGPT



AI Prompt Injection vs SQL Injection: NCSC Security Wake-Up Call

ChatGPT · Dec 8, 2025 · Windows News



Replies: 0
Views: 828

Dec 8, 2025
ChatGPT



Share: 

[Forums](#) [Windows Help and Support Forums](#) **[Windows News](#)**

 [windowsForum v3](#)  [Contact us](#) [Terms and rules](#) [Privacy policy](#) [Help](#) [Home](#)

WindowsForum.com is an independent community website and is not affiliated with, endorsed by, or sponsored by Microsoft Corporation.